BarCat Deals: Ethics Statement

Course: CS 5001 - Senior Design I, University of Cincinnati
Team: Brian Nguyen, Kaustubh Mathur, Ved Sanap, Meredith Bartel, Kiki Vasilev
Advisor: Dr. Hrishikesh Vinayak Bhide
Version: 0.2 | **Date:** November 11, 2026 | **Status:** Reviewed
Documentation lead: Meredith Bartel; component owners review their sections.

1. Privacy summary

Consent before collection: explain the age cookie before the 21+ question; decline/dismiss still permits nonalcohol browsing. Owner onboarding explains public fields, private email, retention and correction/deletion contact; source collection and external AI processing need separate approval. Venue consent cannot grant platform access or other people's consent. Remove incidental names/faces or quarantine the post. Exclude unjustified student GPS, DOB, contacts, advertising IDs and browsing histories. No student uploads/sensors are planned.

Storage/access: planned C4 is encrypted managed PostgreSQL; only C3 has database credentials. C1/C2/C5 use APIs. Restrict operators and exclude private fields from public responses. Verify host/backup encryption and provider retention before real-data testing; Azure controls are unverified.

Data item / fields	Source	Purpose	Consent / notice	Storage	Access	Proposed retention
Venue ID, business name, address, approved coordinates and campus point	Owner / onboarding; team	One-mile eligibility and venue display	Owner agrees to public venue profile; no student location	C4; campus config	Public venue fields; C3 writes	Active profile; remove within 30 days of closure
Contact email	Owner form/profile	Verify representative and resolve submissions	Explicit private-contact explanation	C4; identity provider only as needed	Owner, authorized operator, C3; never public deals/logs	Active account; delete within 30 days of closure
Provider subject, owner ID, role, venue mapping and login token/expiry	Supabase verification; team approval	Confirm who may publish for a venue	Owner accepts login notice; provider notice applies	Identity provider; mapping in C4; bearer token transient	G1/C3; approved identity administrators	Mapping until account closure +30 days; discard bearer after verification
Deal ID, venue link, title, description, category, alcohol flag, price; weekdays, start/end times, effective dates, status	Owner or approved extraction	Present a scheduled offer truthfully	Owner approves publication; extraction requires source approval	C4 deal + source records	Public eligible fields via C3; private author link restricted	Active offer; expired offer removed within 30 days
Source type, original HTTPS URL, deal/post links; observation/check times, confidence	Owner confirmation or validated source	Trace origin, uncertainty and freshness	Explain source link; no implied permission to reuse whole posts	C4 evidence; derived public labels	Public source/check time; private conf idence/evidence	With related offer; delete links together
Feed filters: mode/date/instant, venue/category/alcohol/sort/limit; signed cursor with snapshot/filter/order/expiry	Browser/API	Return eligible pages consistently	Explain functional requests; no analytics reuse	Request memory; signed cursor in response	C1/C3 and requesting browser	Request lifetime; cursor expires after 5 minutes; no query-history table
DealView/FeedResponse: venue/facts/source, schedule, distance, occurrence start/end, remaining minutes, stale flag/count, generated/last-update times, next cursor	C3 computes	Accessible feed/detail presentation	Same public-data notice; age checked before serialization	Browser/C1 memory; no shared response cache	Eligible visitor; C3	Current response/session; no-store headers
Session/CSRF token delivered to browser; stored token/CSRF hashes, identity/role, age answer, expiry/revocation	G1 and visitor answer	Guest age preference and protected browser actions	Explain purpose before age confirmation; no identity proof claimed	Secure cookie/forms; hashes/server state in C4	Browser for its session; C3/G1; no logs	Guest validity 24 h; owner validity <=30 min/provider expiry. Proposed purge within 24 h after expiry/revocation

1.1 Background processing and operational data

Data item / fields	Source	Purpose	Consent / notice	Storage	Access	Proposed retention
Platform/account/external IDs, page URL, approval/withdrawal flag; raw HTML, normalized text <=5,000 characters, 0-10 image URLs, posted/observed times	Approved venue source	Register posts once and support correction	Venue permission plus permitted platform access; public does not mean reusable	Private C4 raw-post store through C3; C5 memory	C3/C5; authorized operators	Raw/failed posts <=30 days; preserve during bounded retries, then operator export only if justified/approved
Minimized post text/images/date sent to model; structured candidates, confidence, validation/disposition	C5; Anthropic API	Extract 0-10 possible offers per post	Explain external processing before enablement; exclude owner email/session data	C5 memory; selected results /evidence in C4; provider processing	C5/C3; provider under accepted terms	Local candidates/raw evidence <=30 days; provider retention must be documented before enabling
Account cursor/due time/backoff; worker ID, claim/heartbeat/lease token/expiry, attempts, completion/failure result	C3/C5 service calls	Bounded recovery without duplicate publication	Operational use described to participating owners	C4 work tables; transient C5 state	C3; authenticated worker; operators	<=30 days; credentials/tokens never public; no old token accepted
Owner/request key, body hash, original response/committed deal ID	Owner submission; C3	Replay lost responses safely	Functional submission notice	C4 REQUEST_ RESULT	C3; submitting owner receives own result	24 h per REQ-06; cleanup job removes expired rows
Attempt/post/month IDs, reserved call cost, approval/cap settings	C3 budget guard; team	Prevent unfunded processing	Source/AI notice; record approved funding	C4 reservations; nonsecret config	C3/C5; maintainers	Current month +30 days; then anonymous cost totals only
Required settings, database/service/identity/AI secret references and keys	Deployment operator	Start only authorized services	Restricted administration	Secret store; nonsecret versioned config; keys in service memory	Minimum required service/operator	Revoke/rotate on exposure, role change or shutdown; no secrets in Git
Timestamp, request ID, component/event/resource ID, status, duration, error code; health/dependency names	Application and host	Diagnose failures without request bodies	Privacy notice explains operational logging	Restricted collector; local buffer <=1,000 events	Authorized maintainers; only minimal health public	<=14 days; drop oldest during collector failure; report drop count
Incidental connection IP/user-agent; backup snapshots; pilot/task-test evidence	HTTPS host; backup job; consenting volunteers	Transport, recovery and acceptance evidence	Tell volunteers tasks/data used; no silent research/ marketing reuse	Host logs/backups; restricted test evidence	Hosting operator; authorized testers	Propose IP logs <=7 days, daily backups on 7-day rolling policy; de-identify evidence within 30 days of pilot/end

Deletion mechanism and project end: Meredith schedules a daily C3 cleanup for the retention rules, verifies counts/foreign keys and records only aggregate deletion results. Owner requests go through a verified operator contact; unpublish first, then delete linked private records within 30 days. Suppression records prevent reimporting withdrawn sources without retaining their raw posts. After restore, rerun deletion/suppression rules before exposing the database. At project end, stop collection, revoke service keys and sessions, delete identity accounts and live private/source data within 30 days, request provider deletion and let approved backups expire within the next 7 days. Keep only synthetic fixtures, public project documentation and de-identified totals in Git. Confirm that the selected host can enforce these limits; otherwise do not collect live data.

Ethical judgment: Alcohol offers could encourage unsafe consumption; keep food prominent and enforce server-held age answers (REQ-02, CON-03). Self-attestation cannot prevent a false answer, so do not advertise it as verified age. Stale prices/times may mislead; show the last check, missing-price text and source rather than inventing facts (REQ-03/04). Hold uncertain extractions and keep automation off until source, funding and quality gates pass (REQ-07, OQ-01/04). These support the existing Constraints essay; they do not claim its risks are eliminated.

Fair access includes owner-only venues, keyboard/screen-reader support and testing different post formats, not only large English-language accounts (CON-02, NFR-04). State that untested languages/formats and venues without approved coordinates are coverage limits; do not infer that an absent offer is unavailable. Brian/Kaustubh collect student/owner feedback; Kiki checks source exclusions. Record any sponsor, venue or vendor relationship with the advisor before it affects ordering or selection; no paid-ranking feature is specified. Stop affected publication and escalate any alcohol leak, private-data exposure or unauthorized source access rather than bypassing a gate for a deadline.

2. Security summary

Default credentials: no application, seed accounts or deployment exists to inspect for a running default password. The project must not deploy sample/admin credentials. Owner identity uses Supabase verification; invitations/mappings restrict owners to their venues. Generate distinct database/worker secrets, store them in the deployment secret store, and restrict maintainer/hosting accounts with MFA. Enforce invitation completion/password reset if temporary accounts are used. These deployment actions remain unverified.

Unauthenticated endpoints: public nonalcohol feed/detail, guest-session creation and minimal health are deliberate exceptions, not open administration. C3 checks age before serializing alcohol, verifies owners and their venue on every write, and requires a service key for every internal worker route. Missing/invalid credentials return 401; insufficient authority returns 403. Restrict detailed diagnostics and database connectivity; only C3 accesses C4. Guest sessions expire after 24 h, authenticated sessions after at most 30 minutes/provider expiry; use hashed 256-bit tokens, Secure/HttpOnly/SameSite=Lax cookies, CSRF checks and persistent revocation (Specification Sections 3.2-3.5).

Secrets in source control: on November 11, 2026, the read-only audit examined all **56 reachable commits** at `6a4350b`, covering **80 unique blobs: 52 text, 13 extracted PDFs, 15 other binaries**. No matching credentials or private keys were found in text/PDF contents, and no credential-file paths were tracked. Rules covered provider-key formats, JWTs, private-key headers, credentialed database URLs and quoted secret assignments; obvious placeholders were excluded. Binary payloads, Git LFS objects, unreachable/deleted refs, remote provider settings and secrets without these patterns were not proved safe. This is a limited negative result, not a security certification. Security Audit records scope and method.

The new `.gitignore` excludes local secret/key files and permits a value-free `.env.example`; ignoring a file does not remove a previously committed secret. If one is found later, revoke/rotate it first, assess exposure and coordinate history cleanup without preserving the value in an issue/report. No credential rotation is claimed from this audit because no credential was identified.

Transport and abuse controls: require HTTPS at browser/API/worker/provider boundaries, parameterized SQL, escaped templates, no-store deal/session responses and redacted errors/logs. Implement per-source/session/IP request limits for guest creation, login, reads and writes, plus provider backoff and bounded work. Numeric application limits are not yet specified; Ved/Kiki must freeze and test them before pilot use. Do not describe 429 handling as a configured rate-limit policy. Private data must not leak into screenshots, request traces, public test evidence or paid API prompts.

Self-audit question	Answer and evidence / remaining check
Are fields justified and consent specific?	Specification 3.3 inventory above; separate owner/source/model notices are proposed, not implemented.
Any default passwords?	No running app/seed credentials exist in this checkout; inspect deployed identities and seed scripts before pilot.
Any exposed protected routes?	Auth/age/CSRF contracts exist; runtime rejection is Not Run. TC-002A-C, TC-005C, TC-013A-C and TC-023 are the checks.
Any committed secrets?	Zero rule matches in the scoped history scan; 15 binary blobs excluded from content inspection. Repeat scanning on every release candidate.
Is storage access/encryption verified?	C3-only credentials are specified; Azure settings, backup encryption and identity-provider controls still need evidence.
Are retention/deletion and recovery tested?	Proposed jobs above; TC-016/017 cover restore/log controls, with added deletion-after-restore checks required before live data.

Release responsibilities: Ved checks authority/session/CSRF failures; Kiki checks keys, source approval and spend/rate gates; Meredith verifies storage, cleanup and recovery; Brian/Kaustubh check that UI errors reveal no private data. On suspected exposure, disable affected access/publication, rotate credentials, preserve redacted incident evidence and notify the advisor and affected parties through the agreed incident process. No incident or passing runtime test is claimed.

3. Licensing summary

The existing LICENSE is **MIT**, copyright 2026 BrianN45, covering project-owned work only. No application source, dependency manifest or lockfile is tracked. **Unpinned** means planned in Specification Section 4, not installed; Python 3.12/PostgreSQL 16 are proposed. Pin patches and audit transitive packages before release. License evidence was checked against SPDX on November 11. Linked names below lead to upstream license/terms; NOTICE.md keeps full authorship credits and the same inventory.

Item	Version / status	SPDX identifier	Type	Obligation / MIT fit
Python + zoneinfo	3.12 proposed	Python-2.0	Permissive	Retain full Python notices; stdlib is not a separate zoneinfo package
Flask	Unpinned, planned	BSD-3-Clause	Permissive	Retain notice/disclaimer; no endorsement claim
Jinja	Unpinned, planned	BSD-3-Clause	Permissive	Same; keep escaping enabled
FastAPI	Unpinned, planned	MIT	Permissive	Preserve copyright/license
Pydantic	Unpinned, planned	MIT	Permissive	Preserve copyright/license
PostgreSQL	16 proposed	PostgreSQL	Permissive	Preserve its copyright/disclaimer
SQLAlchemy	Unpinned, planned	MIT	Permissive	Preserve copyright/license
Alembic	Unpinned, planned	MIT	Permissive	Preserve copyright/license
APScheduler	Unpinned, planned	MIT	Permissive	Preserve copyright/license
httpx	Unpinned, planned	BSD-3-Clause	Permissive	Preserve notice/disclaimer; no endorsement
Anthropic Python SDK	Unpinned, planned	Apache-2.0	Permissive	Preserve license/notices, mark changes, include applicable NOTICE; service terms separate
python-dateutil	Unpinned, planned	BSD-3-Clause	Permissive	Select upstream BSD option; keep its complete LICENSE, including Apache text
pytest	Unpinned, planned	MIT	Permissive	Preserve copyright/license
axe-core	Unpinned, planned test tool	MPL-2.0	Copyleft	Keep separate; preserve notices/source availability for distributed covered files/changes
Supabase Auth source	Hosted version unrecorded	MIT	Permissive	Source license only; hosted identity contract separately required
Browser/server/DB driver	Not selected/pinned	Not determined	Unresolved	No blanket compatibility claim; record chosen packages/licenses before use
Timezone data	Version not recorded	LicenseRef-TZDB	Public domain	Record IANA data release; audit any packaged compiler/wrapper separately
Venue posts/flyers/owner data	No live dataset in repo	LicenseRef-Venue-Content	Restricted	Permission, minimization and source attribution; not relicensed MIT
Azure / Supabase Cloud / Anthropic API	Plan/model/terms to approve	LicenseRef-Service-Terms	Contract	Review each accepted service agreement and data settings before enabling
Team diagrams/fixtures	Current designs / planned fixtures	MIT for own material	Project	Credit team; no imported logos/photos identified
Arial / Consolas in documents	Local 7.06 / 7.01	LicenseRef-Microsoft-Fonts	Proprietary	Document embedding only as permitted; do not redistribute font files or ship them in app

Compatibility decisions: preserve MIT/BSD/PostgreSQL/Python and Apache obligations alongside project MIT work; unknown versions are not cleared. **axe-core is weak copyleft:** retain MPL-covered files/notices and provide covered source when distributing; separate files can remain MIT under MPL Section 3.3. Keep it a separate test tool. No GPL/AGPL app component is selected. Unknown licenses, permissions or service terms block the affected integration.

Document tools: ReportLab 4.4.9 (BSD-3-Clause), pypdf 6.21.4 (BSD-3-Clause), pdfplumber 0.11.9 (MIT) and Poppler 26.07.0 (GPL-2.0-or-later) are external authoring/audit tools, not shipped app code. Preserve their licenses if distributing tools. Mermaid is MIT; its prior version is unrecorded. Fonts remain proprietary with editable document-embedding flags; no font files are shipped. LicenseRef labels name restricted/nonstandard terms defined in NOTICE.md, not open-source licenses.

4. Attribution list

Section 3 links the dependencies, data and font sources; NOTICE.md names authors and keeps full credits. Meredith maintains it. No adapted application/tutorial code or imported icons/photos/audio were identified; record author, source, license and changes before reuse. Team diagrams are project work; Microsoft font rights remain separate. Fixtures are synthetic specifications; no live corpus is committed. Real posts need source/date/permission records and restricted storage. X terms require express scraping permission; owner consent alone is insufficient (OQ-01).

5. AI-use disclosure

"Generative AI tools may be used for drafting and code assistance but not for the design decisions or written analysis that are assessed in this course."

Tool	Used by	Task	Column	How verified
ChatGPT / Codex	All team members	Simplified wording, explained test labels, formatted diagrams/PDFs, and maintained links	Generally OK	Assistant text/link comparisons and rendered-page checks were performed
Codex / Claude / GitHub Copilot	All team members	Code assistance and bug fixing	Generally OK	Team members will verify the code created by these AI tools meet team standards.

Typed-name signatures: These signatures are confirmations of design authorship.

- Brian Nguyen
- Kaustubh Mathur
- Ved Sanap
- Meredith Bartel
- Kiki Vasilev